

VindobonaPay GmbH — NIS2 Applicability & Gap Analysis

Directive (EU) 2022/2555 — Articles 20, 21(2)(a)-(j), 23 | Version 1.0 | Fictional company for educational purposes

#	NIS2 requirement	Article	Applicability	Applicability note	Status	Supporting evidence (ISMS)	Gap description	Remediation action	Owner	Target
N-01	Management body approval, oversight and cybersecurity training	Art. 20	Applies directly	Governance duties are not part of the ICT risk-management carve-out. DORA Art. 5 sets an equivalent, stricter duty.	Partial	A.5.4 management responsibilities; management review meetings; InfoSec Policy approved by management.	Policies are approved and reviewed, but there is no formal cybersecurity training programme for the management body and no record of it.	Deliver a yearly ICT risk briefing to the management body and keep attendance records.	CISO	Q4 2026
N-02	Risk analysis and information system security policies	Art. 21(2)(a)	Superseded by DORA	Covered by the DORA ICT risk management framework (Art. 6 et seq.).	Compliant	ISMS risk assessment methodology; Risk Register with 16 risks (Deliverable 02); InfoSec Policy v1.0.	No gap: risk assessment, register and treatment decisions are documented and reviewed.	Maintain the yearly review cycle; align framework documentation with DORA Art. 6.	CISO	Ongoing
N-03	Incident handling	Art. 21(2)(b)	Superseded by DORA	Covered by DORA Art. 17 (incident management process) and Art. 18 (classification).	Partial	A.5.24 to A.5.27; Incident Response Plan v1.1 with triage criteria; incident response runbooks.	Incident handling works internally, but incidents are not classified against the regulatory criteria that determine reporting obligations.	Add a classification step aligned with DORA criteria to the Incident Response Plan.	CISO	Q1 2027
N-04	Business continuity, backup management and crisis management	Art. 21(2)(c)	Superseded by DORA	Covered by DORA Art. 11 (response and recovery) and Art. 12 (backup and restoration).	Partial	A.5.29, A.5.30, A.8.13, A.8.14; Azure Backup with restore tests; RTO/RPO defined; BCP in draft.	Backups are tested, but the Business Continuity Plan is still in draft and no ICT continuity test has been run yet.	Approve the BCP and run the first ICT continuity test.	COO	Q4 2026
N-05	Supply chain security	Art. 21(2)(d)	Superseded by DORA	Covered by DORA Art. 28 to 30, which are considerably more detailed (register of information, contractual provisions, exit strategies).	Gap	A.5.19 to A.5.22; supplier list with risk rating (partial); security clauses in the main contracts.	No structured supplier assessment cycle, no register of ICT contractual arrangements and no exit strategies for critical services.	Build the ICT third-party risk procedure and the register of information (see Deliverable 05).	Compliance Officer	Q1 2027
N-06	Security in acquisition, development and maintenance, including vulnerability handling	Art. 21(2)(e)	Superseded by DORA	Covered by the DORA ICT risk framework (Art. 8, 9) and testing requirements (Art. 24, 25).	Partial	A.8.8, A.8.25 to A.8.29, A.8.32; SAST in the CI pipeline; yearly external penetration test; monthly vulnerability scans.	Secure development practices are in place but the SDLC procedure is not formalized, and patch SLAs by severity are not defined.	Formalize the secure SDLC procedure and define patch SLAs by severity.	Head of Engineering	Q4 2026
N-07	Policies and procedures to assess the effectiveness of risk-management measures	Art. 21(2)(f)	Superseded by DORA	Covered by DORA Art. 6(5)(6) (framework review and internal audit) and Chapter IV (resilience testing).	Gap	ISMS Clause 9 requirements; A.5.35 independent review; no internal audit performed yet.	The first internal ISMS audit has not been carried out, so control effectiveness is not yet independently assessed.	Schedule and run the first internal ISMS audit; plan the resilience testing programme.	Management	Q1 2027
N-08	Basic cyber hygiene practices and cybersecurity training	Art. 21(2)(g)	Superseded by DORA	Covered by DORA Art. 13(6) (awareness programmes and training).	Compliant	A.6.3; yearly awareness training for all staff; phishing simulations; training records kept.	No gap for general staff. Management-level training is tracked separately under N-01.	Maintain the yearly cycle and extend simulations to new joiners.	CISO	Ongoing
N-09	Policies and procedures on the use of cryptography and encryption	Art. 21(2)(h)	Superseded by DORA	Covered by DORA Art. 9 (protection and prevention).	Compliant	A.8.24; cryptography standard; TLS in transit; encryption at rest in Azure; full-disk encryption on laptops.	No gap: encryption is applied in transit, at rest and on endpoints, with documented key management.	Review the cryptography standard yearly against evolving guidance.	Head of Engineering	Ongoing
N-10	Human resources security, access control policies and asset management	Art. 21(2)(i)	Superseded by DORA	Covered by DORA Art. 8 (identification) and Art. 9 (protection).	Partial	A.6.1 to A.6.6; A.5.15 to A.5.18; A.8.2, A.8.3; asset inventory; Access Control Policy v1.0.	HR security and asset inventory are in place; access reviews are still ad-hoc rather than a quarterly cycle, and the segregation of duties matrix is in draft.	Introduce quarterly access reviews and finalize the segregation of duties matrix.	IT Manager	Q4 2026
N-11	Multi-factor authentication and secured communications	Art. 21(2)(j)	Superseded by DORA	Covered by DORA Art. 9. NIS2 names MFA explicitly; DORA requires strong authentication as part of protection measures.	Partial	A.8.5, A.8.2; MFA and Conditional Access enforced in Entra ID; separate admin accounts.	MFA is enforced for all users, but enrollment for privileged accounts is not yet complete and phishing-resistant methods are not in use.	Complete MFA enrollment for privileged accounts and introduce FIDO2 keys for administrators and finance staff.	IT Manager	Q3 2026
N-12	Incident notification to the authorities (early warning 24h, notification 72h, final report 1 month)	Art. 23	Superseded by DORA	Covered by DORA Art. 19 for major ICT-related incidents. Reports go to the financial competent authority, not to the CSIRT under the NIS2 regime.	Gap	A.5.5 authority contact list (FMA, CERT.at); A.5.31 legal and regulatory register.	Authority contacts exist, but there is no documented reporting workflow with deadlines, templates and responsibilities.	Define the regulatory incident reporting procedure with DORA timelines (see Deliverable 05).	Compliance Officer	Q1 2027

Status:

Compliant

Partial

Gap

Applicability:

Applies directly

Superseded by DORA

Legal basis for the carve-out: NIS2 Art. 4 (sector-specific Union legal acts) and DORA Art. 1(2), confirmed by DORA Recital 16 and NIS2 Recital 28, and by the European Commission guidelines on the application of Art. 4(1) and (2) of Directive (EU) 2022/2555.

Requirements marked 'Superseded by DORA' remain documented: the equivalent DORA obligation is generally stricter, and the reasoning must be visible to an auditor.

Sources: EUR-Lex (Directive (EU) 2022/2555; Regulation (EU) 2022/2554). No regulatory text is reproduced: articles are referenced by number and described in my own words.

NIS2 Gap Analysis — Summary

Values calculated automatically from the gap analysis sheet.

Requirements assessed	12
-----------------------	----

BY STATUS

Compliant	3
Partial	6
Gap	3

BY APPLICABILITY

Applies directly	1
Superseded by DORA	11

The three gaps — supply chain security, effectiveness assessment and incident notification — are the same areas flagged as 'Beyond ISMS' in Deliverable 03. All three are addressed under DORA in Deliverable 05.

Only Art. 20 (management body accountability) applies directly. The remaining requirements are superseded by the equivalent DORA provisions for financial entities.